HACKTHEBOX

MEETUPS

Patras, GR

Meetup #3

- Introduction.

Nikolas Filippatos
Cybersecurity Research Associate, University of Patras, ISSG

github.com/nikolasfil
linkedin.com/in/nikolas-filippatos



Supported By

HackTheBox

ISSG

Information Systems Security Group, University of Patras





Wifi for Upatras.

Guest Wifi

Wifi ssid: eduroam

Username: **ecedutwo@upatras.gr**

Password: **driatriwai**

Powerpoint Presentation.

Cybersecurity-Wiki
github.com/nikolasfil/Cybersecurity-Wiki/wiki/meetup-03

- Tools and evidence.

Use each tool to answer a concrete question.

Services, names, and virtual hosts.

Nmap

Find reachable ports, identify services, and read version clues. A version can lead to a disclosed vulnerability.

One IP, several sites

DNS or a hosts-file maps a name to an IP. The HTTP Host header selects a virtual host; TLS names are clues.

References

Nmap reference

Find the surface: Gobuster and ffuf.

Gobuster

Bruteforce your way through finding what the website has to offer. Directory mode finds paths. Virtual-host mode tests hostnames. Choose a bounded wordlist.

ffuf

Bruteforce with more controlled fuzzing. Replace FUZZ in a URL or header and try any combination you want.

References

Gobuster · ffuf · SecLists

Read HTTP; research the exact product.

Browser, curl, Burp

Capture a normal request. In Repeater, change one value and compare status, headers, and body.

Wappalyzer + advisories

Fingerprinting suggests a technology. Verify product, version, and prerequisites before trusting a CVE.

References

Burp Repeater · Wappalyzer

- Web concepts.

A request can cross more than one trust boundary.



Templates and local file inclusion.

What is a template?

A server-side file used to render a page. A user-selected name should resolve only to an allowed template.

Why can it go wrong?

Path traversal can escape the intended folder. Including PHP may execute it; file inclusion is not always file disclosure.

References

PrivateBin advisory · Path traversal

MCP in two minutes.

Crash course 1 of 2.

What is it?

Model Context Protocol connects an AI host to external capabilities through a client and a server.

How is it used?

A server can offer tools (actions), resources (data), and prompts (templates). A local client may launch it over stdio.

Why here?

An inspector can start a server process. Who may control that launch, and whose OS rights does it inherit?

MCP introduction · stdio + Inspector

Docker in two minutes.

Crash course 2 of 2.

Image → container

An image packages an app. A container is a running instance with its own process and filesystem view.

Shared files

A bind mount maps a host path into a container. Read/write access depends on mount and filesystem permissions.

Why here?

Docker Engine runs a daemon. Access to shared files and access to the daemon are distinct privilege boundaries.

Docker Engine · Bind mounts · Security

Reverse shell: who connects to whom?

Callback direction

The target initiates a connection to a listener on your reachable VPN address. The listener must be ready.

Identity matters

The shell inherits the process user and groups. Check id before claiming access to another account or host.

References

Netcat manual

- Privilege escalation.

From a foothold, inspect permissions before testing a lead.

What is privilege escalation?

The question

What can this user read, write, execute, or ask a privileged service to do?

The boundary

A shell inside an app or container has a specific identity. Host root is a separate claim to prove.

Enumerate before escalating.

Manual first

Identity and groups; sudo rules; ownership and modes; processes; services and local sockets.

Then automate

linPEAS helps spot leads. Check each promising finding against the actual permissions and execution context.

References

PEASS-ng / linPEAS

Common Linux privilege boundaries.

Programs

SUID, capabilities, and sudo may give a specific binary more authority than your shell.

Scheduled work

A privileged job can be unsafe if it runs a file or command another user can alter.

Services + groups

A local socket or shared file may let one account influence another service.

GTFOBins · Docker group privileges

How to use linPEAS and GTFOBins.

linPEAS

An enumeration checklist with highlighted leads. It reports possibilities, not confirmed exploits.

GTFOBins

Look up a binary only after confirming the exact permission and invocation. Test the relevant condition.

References

PEASS-ng · GTFOBins

- Machines.

Very Easy and Easy.

Very Easy

Meow

Preignition

Ignition

Easy

Reactor

Kobold

Soccer

YARA_Rule

VoIP

Medium.

Medium

DevArea

HackNet

Cat

ShadowDropLoader

Hard and Insane.

Hard

Sorcery

Lantern

Insane

WhiteRabbit

More tools ?

100-tool quick reference

In the Wiki there is a new file listing most popular 100 tools for cybersecurity and a table cross referencing the roles that might utilize them.

References

CybersecurityWiki.wiki

HACKTHEBOX

MEETUPS

Patras, GR

Thank you!